

PS01 – Plan de Gestion de Riesgos y Amenazas

ID Documento: GOYA-PS01-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Confidencial **Proximo revision:** 2027-03-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Oficial de Seguridad	Documento inicial

1. Objetivo y Alcance

1.1 Objetivo

Establecer el proceso sistematico de gestion de riesgos para Goya Ledger SpA en su calidad de Prestador de Servicios de Certificacion (PSC) bajo la Ley 19.799 y su reglamento DS 181/2002. Este documento cumple con el sub-proceso PS01 de la Guia de Acreditacion EA-103 v2.1 de la Entidad Acreditadora (Subsecretaria de Economia).

1.2 Alcance

El alcance cubre la totalidad de la organizacion y sus servicios de confianza:

- **Autoridad Certificadora (CA):** Emision de certificados X.509 para Firma Electronica Avanzada (FEA) con ML-DSA-65 (FIPS 204).
- **Autoridad de Sellado de Tiempo (TSA):** Sellos de tiempo RFC 3161 con precision NTP verificada.
- **Respondedor OCSP:** Consultas de estado de certificados en tiempo real (RFC 6960).
- **Autoridad de Registro (RA):** Verificacion de identidad presencial y remota (Smart-ID, ClaveUnica).
- **Infraestructura de soporte:** Nodos blockchain BFT (Rust/Actix-Web 4), almacenamiento RocksDB, red P2P con TLS 1.3.
- **Aplicacion de escritorio:** Tauri v2 (light client) para operaciones de firma.

1.3 Entorno regulatorio

Norma	Aplicacion
Ley 19.799	Documentos electronicos, firma electronica y PSC
DS 181/2002	Reglamento de la Ley 19.799
Decreto 24/2019	Norma tecnica para FEA
Ley 19.628	Proteccion de datos personales
Ley 21.459	Delitos informaticos
EA-103 v2.1	Guia de acreditacion de PSC
ISO/IEC 27001:2022	Sistema de gestion de seguridad de la informacion
ISO/IEC 27005:2022	Gestion de riesgos de seguridad de la informacion
NIST SP 800-30 Rev.1	Guia para la evaluacion de riesgos
ETSI TS 102 042	Requisitos de politica para CA que emiten certificados cualificados
ETSI EN 319 401	Requisitos generales para prestadores de servicios de confianza

1.4 Descripcion de la organizacion

Goya Ledger opera como PSC con infraestructura basada en blockchain con consenso BFT (HotStuff + DPoS). La plataforma utiliza criptografia post-cuantica ML-DSA-65 (FIPS 204, nivel de seguridad NIST 3) para firmas FEA y Ed25519 para firmas electronicas simples (FES). La identidad se gestiona mediante DIDs (`did:goya:{pubkey_hex[. .16]}`).

La infraestructura de produccion opera en Fly.io (region IAD) con nodos BFT replicados. La entidad legal principal esta registrada en Estonia (EU TSP path), con SpA chilena en proceso de constitucion.

2. Metodologia de Evaluacion de Riesgos

2.1 Marco metodologico

Se adopta ISO/IEC 27005:2022 como marco principal, complementado con NIST SP 800-30 Rev.1 para la taxonomia de amenazas y el calculo de riesgo. El proceso sigue los ocho sub-procesos exigidos por EA-103 v2.1 seccion 4.8:

1. Establecimiento del contexto
2. Identificacion de riesgos
3. Estimacion de riesgos
4. Evaluacion de riesgos
5. Tratamiento de riesgos
6. Aceptacion de riesgos

7. Comunicacion de riesgos
8. Monitoreo y revision de riesgos

2.2 Escala de probabilidad

Nivel	Valor	Descripcion	Frecuencia estimada
Muy baja	1	Evento excepcional, sin precedentes conocidos	< 1 vez en 10 anos
Baja	2	Evento poco probable pero posible	1 vez cada 3-10 anos
Media	3	Evento plausible con precedentes en la industria	1 vez cada 1-3 anos
Alta	4	Evento probable, ocurre regularmente en el sector	1 vez al ano o mas
Muy alta	5	Evento casi seguro, ocurre frecuentemente	Varias veces al ano

2.3 Escala de impacto

Nivel	Valor	Operacional	Financiero	Reputacional	Regulatorio
Muy bajo	1	Degradacion menor sin afectar servicio	< 1.000 USD	Sin cobertura	Observacion interna
Bajo	2	Interrupcion parcial < 1 hora	1.000-10.000 USD	Mencion aislada	Advertencia regulatoria
Medio	3	Interrupcion de servicio 1-4 horas	10.000-100.000 USD	Cobertura sectorial	Sancion menor
Alto	4	Interrupcion > 4 horas o compromiso de datos	100.000-1.000.000 USD	Cobertura nacional	Suspension temporal
Muy alto	5	Compromiso de claves CA o emision fraudulenta masiva	> 1.000.000 USD	Crisis de confianza publica	Revocacion de acreditacion

2.4 Matriz de riesgo 5x5

	Impacto 1	Impacto 2	Impacto 3	Impacto 4	Impacto 5
Probabilidad 5	5 (Bajo)	10 (Medio)	15 (Alto)	20 (Critico)	25 (Critico)
Probabilidad 4	4 (Bajo)	8 (Medio)	12 (Medio)	16 (Alto)	20 (Critico)
Probabilidad 3	3 (Bajo)	6 (Bajo)	9 (Medio)	12 (Medio)	15 (Alto)
Probabilidad 2	2 (Bajo)	4 (Bajo)	6 (Bajo)	8 (Medio)	10 (Medio)
Probabilidad 1	1 (Bajo)	2 (Bajo)	3 (Bajo)	4 (Bajo)	5 (Bajo)

2.5 Niveles de riesgo

Nivel	Rango	Accion requerida
Bajo	1-6	Aceptar con monitoreo. Revisar anualmente.
Medio	7-12	Mitigar dentro de 6 meses. Plan de tratamiento requerido.
Alto	13-19	Mitigar dentro de 3 meses. Aprobacion de gerencia requerida.
Critico	20-25	Mitigar de inmediato. Escalacion al directorio. Operacion condicional.

3. Inventario de Activos

3.1 Activos criptograficos

ID	Activo	Descripcion	Confidencialidad	Integridad	Disponibilidad
AC-01	Clave privada CA raiz	ML-DSA-65, almacenada offline en fragmentos M-of-N	Critica	Critica	Baja (uso excepcional)
AC-02	Clave privada CA intermedia	ML-DSA-65, operativa en servidor	Critica	Critica	Alta
AC-03	Clave privada TSA	ML-DSA-65, sellado de tiempo	Critica	Critica	Alta

ID	Activo	Descripcion	Confidencialidad	Integridad	Disponibilidad
AC-04	Clave privada OSCP	ML-DSA-65, firma de respuestas OSCP	Critica	Critica	Alta
AC-05	Claves de suscriptores	Ed25519 (FES) o ML-DSA-65 (FEA), generadas cliente	Alta	Alta	Media
AC-06	Certificados X.509 emitidos	Certificados FEA de suscriptores	Publica	Critica	Alta

3.2 Activos de datos

ID	Activo	Descripcion	Confidencialidad	Integridad	Disponibilidad
AD-01	Registro de auditoria	Cadena hash SHA-256 append-only en RocksDB	Media	Critica	Alta
AD-02	Blockchain (estado)	Bloques BFT con transacciones firmadas	Baja	Critica	Alta
AD-03	Base de datos de certificados	Certificados emitidos, revocados, CRL	Baja	Critica	Alta
AD-04	Registros de identidad RA	Datos de verificacion de identidad de suscriptores	Alta	Alta	Media
AD-05	Datos personales suscriptores	Nombre, RUT, correo, datos de contacto (Ley 19.628)	Alta	Alta	Media
AD-06	Codigo fuente	Repositorio Rust del sistema completo	Media	Alta	Media
AD-07	Configuracion del sistema	Variables de entorno,	Alta	Alta	Alta

ID	Activo	Descripcion	Confidencialidad	Integridad	Disponibilidad
AD-08	Compromisos biometricos	archivos de configuracion Hashes SHA-256 de evidencia biometrica	Media	Critica	Media

3.3 Activos de infraestructura

ID	Activo	Descripcion	Confidencialidad	Integridad	Disponibilidad
AI-01	Nodos BFT (Fly.io IAD)	Servidores Actix-Web 4 con consenso HotStuff	Media	Alta	Alta
AI-02	Almacenamiento RocksDB	Base de datos persistente por nodo	Media	Critica	Alta
AI-03	Red P2P	Comunicacion TCP/TLS entre nodos	Media	Alta	Alta
AI-04	API Gateway	Endpoints REST bajo / api/v1	Baja	Alta	Alta
AI-05	Fuente de tiempo NTP	Sincronizacion temporal para TSA	Baja	Critica	Alta
AI-06	Sistema de backup	Checkpoints RocksDB, respaldos off-site	Alta	Alta	Media
AI-07	Aplicacion desktop Tauri	Light client macOS para operaciones de firma	Baja	Alta	Media

3.4 Activos intangibles

ID	Activo	Descripcion	Confidencialidad	Integridad	Disponibilidad
AT-01	Reputacion del PSC	Confianza publica en los servicios de certificacion	N/A	Critica	N/A
AT-02	Acreditacion PSC	Licencia otorgada por Entidad Acreditadora	N/A	Critica	N/A

ID	Activo	Descripcion	Confidencialidad	Integridad	Disponibilidad
AT-03	Relaciones con suscriptores	Contratos y obligaciones con titulares de certificados	Media	Alta	N/A

4. Catalogo de Amenazas

4.1 Desastres naturales

ID	Amenaza	Descripcion
AN-01	Terremoto	Dano fisico a datacenter primario (zona sismica Chile)
AN-02	Inundacion	Inundacion por lluvias, rotura de caneria, o tsunami costero
AN-03	Incendio	Incendio en instalaciones o datacenter
AN-04	Corte electrico prolongado	Falla de suministro electrico regional > 24 horas

4.2 Amenazas humanas deliberadas – ataque externo

ID	Amenaza	Descripcion
AE-01	Ataque de denegacion de servicio (DDoS)	Saturacion de API Gateway o red P2P
AE-02	Intrusion a servidores	Acceso no autorizado a nodos BFT o sistemas de soporte
AE-03	Robo de claves criptograficas	Exfiltracion de claves privadas CA, TSA u OSCP
AE-04	Ingenieria social	Phishing o pretexting contra personal con acceso a sistemas
AE-05	Ataque a cadena de suministro	Compromiso de dependencias Rust (crates) o imagen de contenedor
AE-06	Inyeccion de solicitudes fraudulentas de certificados	Solicitudes de certificados con identidad falsa
AE-07	Ataque man-in-the-middle	Interceptacion de comunicaciones P2P o API
AE-08	Explotacion de vulnerabilidades conocidas (CVE)	Uso de vulnerabilidades publicas en dependencias

4.3 Amenazas humanas deliberadas – amenaza interna

ID	Amenaza	Descripcion
AI-01	Abuso de privilegios por administrador	Emision no autorizada de certificados por operador con acceso
AI-02	Exfiltracion de datos por personal	Copia no autorizada de claves o datos de suscriptores
AI-03	Sabotaje interno	Destruccion o corrupcion deliberada de datos o configuracion

4.4 Amenazas humanas accidentales

ID	Amenaza	Descripcion
HA-01	Error de configuracion	Cambio erroneo de variables de entorno o parametros criticos
HA-02	Eliminacion accidental de datos	Borrado de claves, certificados o registros de auditoria
HA-03	Despliegue de codigo defectuoso	Push de version con errores a produccion
HA-04	Error en proceso de RA	Verificacion de identidad incorrecta que aprueba suscriptor no valido

4.5 Amenazas tecnicas

ID	Amenaza	Descripcion
AT-01	Falla de hardware de servidor	Falla de disco, CPU o memoria en nodo BFT
AT-02	Corrupcion de base de datos RocksDB	Corrupcion de WAL o SST files
AT-03	Falla de sincronizacion NTP	Desviacion temporal que invalida sellos de tiempo TSA
AT-04	Falla de software (bug)	Error en logica de consenso, firma o validacion
AT-05	Agotamiento de almacenamiento	Disco lleno en nodos de produccion
AT-06	Expiracion de certificados de infraestructura	Vencimiento de certificados TLS de nodos o CA intermedia
AT-07	Degradacion de rendimiento	Saturacion de CPU o memoria bajo carga elevada

4.6 Amenazas especificas de blockchain

ID	Amenaza	Descripcion
BC-01	Manipulacion de consenso BFT	Nodos bizantinos ($> f$ en $3f+1$) que subvierten el consenso

ID	Amenaza	Descripcion
BC-02	Fork de cadena	Division de la cadena por particion de red o bug de consenso
BC-03	Envenenamiento de gossip	Inyeccion de mensajes AliveMessage con firmas validas pero datos maliciosos
BC-04	Ataque Sybil a DPoS	Creacion masiva de identidades para acumular votos en delegacion

4.7 Amenazas cuanticas

ID	Amenaza	Descripcion
QC-01	Harvest-now-decrypt-later (HNDL)	Captura de firmas Ed25519 actuales para ruptura futura con computador cuantico
QC-02	Ruptura de algoritmo clasico	Computador cuantico capaz de romper Ed25519/ECDSA en operacion
QC-03	Riesgo de transicion criptografica	Fallo durante migracion de Ed25519 a ML-DSA-65 en red mixta
QC-04	Debilidad en implementacion PQC	Vulnerabilidad en la implementacion de ML-DSA-65 (canal lateral, error de biblioteca)

5. Evaluacion de Vulnerabilidades

5.1 Vulnerabilidades por par activo-amenaza

Activo	Amenaza	Vulnerabilidad	Controles actuales	Nivel residual
AC-01 (Clave raiz CA)	AE-03 (Robo de claves)	Fragmentos M-of-N distribuidos en custodios separados	Ceremonia de claves, almacenamiento offline, no conectada a red	Bajo
AC-02 (Clave CA intermedia)	AE-02 (Intrusion)	Clave operativa en memoria del servidor	TLS 1.3, ACL deny-by-default, aislamiento de red Fly.io	Medio
AC-02 (Clave CA intermedia)	AI-01 (Abuso privilegios)	Administrador con acceso a servidor puede acceder a clave	Separacion de roles, auditoria de acceso, principio de minimo privilegio	Medio
AD-01 (Registro auditoria)	HA-02 (Eliminacion accidental)	Cadena hash append-only impide modificacion	RocksDB WAL, checkpoints horarios, replicas en nodos BFT	Bajo

Activo	Amenaza	Vulnerabilidad	Controles actuales	Nivel residual
		pero no eliminacion del storage		
AD-04 (Registros RA)	AE-06 (Solicitudes fraudulentas)	Verificacion de identidad depende de proveedor externo	IdentityVerificationProvider trait, Smart-ID, validacion documental	Medio
AD-05 (Datos personales)	AE-02 (Intrusion)	Datos almacenados en RocksDB sin cifrado a nivel de campo	Cifrado en transito TLS, ACL por endpoint, aislamiento de red	Medio
AI-01 (Nodos BFT)	AE-01 (DDoS)	API expuesta a internet	Rate limiting configurable (RPS/RPM/RPH), Fly.io edge proxying	Medio
AI-01 (Nodos BFT)	AT-01 (Falla hardware)	Instancias cloud sin redundancia de disco local	Consenso BFT tolera f fallas, sync de estado entre pares	Bajo
AI-02 (RocksDB)	AT-02 (Corrupcion)	Corrupcion posible por crash durante escritura	WAL habilitado, checkpoints periodicos, verificacion de integridad	Bajo
AI-03 (Red P2P)	AE-07 (MITM)	Comunicacion entre nodos	mTLS obligatorio, verificacion de firma en gossip	Bajo
AI-05 (Fuente NTP)	AT-03 (Falla NTP)	TSA depende de precision temporal	NtpTimeSource::validate(), multiples servidores NTP	Medio
AC-05 (Claves suscriptor)	QC-01 (HNDL)	Claves Ed25519 (FES) vulnerables a computacion cuantica	Migracion disponible a ML-DSA-65, modo mixto operativo	Medio
AD-06 (Codigo fuente)	AE-05 (Supply chain)	Dependencias de terceros (crates Rust)	cargo-audit en CI, Cargo.lock con versiones fijadas	Medio
AT-01 (Reputacion)	AE-06 (Certificados fraudulentos)	Emision de certificado a identidad falsa dana confianza	Proceso RA con verificacion presencial/remota, auditoria	Medio

6. Registro de Riesgos

ID	Amenaza	Activo afectado	Prob.	Imp.	Riesgo	Nivel	Tratamiento	Control ISO 27002:2022
R-01	AE-03: Robo de clave privada CA raiz	AC-01	1	5	5	Bajo	Mitigar	A.8.24 (Uso de criptografia)
R-02	AE-03: Robo de clave privada CA intermedia	AC-02	2	5	10	Medio	Mitigar	A.8.24, A.8.2 (Derechos de acceso privilegiado)
R-03	AE-02: Intrusion a nodos BFT	AI-01	3	4	12	Medio	Mitigar	A.8.20 (Seguridad de redes), A.8. (Autenticacion segura)
R-04	AE-01: DDoS contra API Gateway	AI-04	4	3	12	Medio	Mitigar	A.8.26 (Requisitos de seguridad de aplicaciones)
R-05	AI-01: Emision no autorizada por administrador	AC-02, AD-03	2	5	10	Medio	Mitigar	A.5.3 (Segregacion de funciones), A.8.15 (Registro de eventos)
R-06	AE-06: Certificado emitido a identidad falsa	AD-03, AT-01	3	5	15	Alto	Mitigar	A.5.17 (Verificacion de identidad), A.8.
R-07	AT-03: Falla de sincronizacion NTP en TSA	AI-05, AC-03	3	4	12	Medio	Mitigar	A.8.17 (Sincronizacion de relojes)
R-08	BC-01: Manipulacion de consenso BFT	AI-01, AD-02	1	5	5	Bajo	Mitigar	A.8.24
R-09	BC-02: Fork de cadena	AD-02	2	4	8	Medio	Mitigar	A.8.25 (Ciclo de desarrollo seguro)
R-10	QC-01: Harvest-now-decrypt-later sobre FES	AC-05	3	4	12	Medio	Mitigar	A.8.24
R-11	QC-02: Ruptura de Ed25519 por computador cuantico	AC-05, AD-02	1	5	5	Bajo	Mitigar	A.8.24
R-12	QC-03: Fallo en transicion cripto FES a FEA	AC-05	2	4	8	Medio	Mitigar	A.8.32 (Gestion de cambios), A.8.
R-13	QC-04: Vulnerabilidad en	AC-02, AC-03	2	5	10	Medio	Mitigar	A.8.28 (Codificacion segura), A.8.8 (Gestion de

ID	Amenaza	Activo afectado	Prob.	Imp.	Riesgo	Nivel	Tratamiento	Control ISO 27002:2022
	implementacion ML-DSA-65							vulnerabilidad tecnicas)
R-14	AE-04: Phishing contra operador PKI	AC-02, AD-04	3	4	12	Medio	Mitigar	A.6.3 (Concientizaci en seguridad), A.8.5
R-15	AE-05: Compromiso de dependencia Rust (crate)	AD-06	2	4	8	Medio	Mitigar	A.8.25, A.5.21 (Seguridad en cadena de suministro TIC)
R-16	AT-02: Corrupcion de RocksDB	AI-02, AD-01	2	4	8	Medio	Mitigar	A.8.13 (Respa de informacion)
R-17	HA-01: Error de configuracion critica	AI-01, AI-04	3	3	9	Medio	Mitigar	A.8.9 (Gestion configuracion)
R-18	HA-03: Despliegue de codigo con errores	AI-01, AD-02	3	3	9	Medio	Mitigar	A.8.25, A.8.31 (Separacion de ambientes)
R-19	HA-02: Eliminacion accidental de registros de auditoria	AD-01	2	4	8	Medio	Mitigar	A.5.33 (Protec de registros)
R-20	AT-06: Expiracion de certificado TLS de nodo	AI-01, AI-03	3	3	9	Medio	Mitigar	A.8.24
R-21	AN-01: Terremoto en datacenter	AI-01, AI-02	2	4	8	Medio	Transferir	A.5.29 (Seguri de la informac durante disrupcion)
R-22	AN-03: Incendio en instalaciones	AI-01, AI-06	2	4	8	Medio	Mitigar	A.7.5 (Protecc contra amenazas fisicas)
R-23	AE-08: Explotacion de CVE en dependencia	AI-01, AD-06	3	3	9	Medio	Mitigar	A.8.8
R-24	BC-03: Envenenamiento de protocolo gossip	AI-03, AD-02	2	3	6	Bajo	Mitigar	A.8.20
R-25	BC-04: Ataque Sybil a DPoS	AD-02	2	4	8	Medio	Mitigar	A.8.5, A.5.17
R-26			2	4	8	Medio	Mitigar	

ID	Amenaza	Activo afectado	Prob.	Imp.	Riesgo	Nivel	Tratamiento	Control ISO 27002:2022
	AI-02: Exfiltracion de datos por personal	AD-04, AD-05						A.5.10 (Uso aceptable de informacion), A.6.2 (Terminacion de condiciones de empleo)
R-27	AI-03: Sabotaje interno	AI-01, AD-02	1	5	5	Bajo	Mitigar	A.5.3, A.8.15, A.6.5 (Responsabilidad post-empleo)
R-28	HA-04: Error en verificacion de identidad RA	AD-04, AT-01	3	4	12	Medio	Mitigar	A.5.17, A.8.15
R-29	AE-07: Man-in-the-middle en comunicacion P2P	AI-03	1	4	4	Bajo	Mitigar	A.8.20, A.8.24
R-30	AT-05: Agotamiento de almacenamiento en nodo	AI-02	3	3	9	Medio	Mitigar	A.8.6 (Gestion de capacidad)
R-31	AN-04: Corte electrico prolongado	AI-01	2	3	6	Bajo	Transferir	A.7.11 (Servicio de soporte), A.8.1
R-32	AT-04: Bug en logica de consenso o firma	AD-02, AC-02	2	5	10	Medio	Mitigar	A.8.28, A.8.25, A.8.29 (Pruebas de seguridad)
R-33	AN-02: Inundacion en datacenter	AI-01	1	4	4	Bajo	Transferir	A.7.5
R-34	AT-07: Degradacion de rendimiento bajo carga	AI-01, AI-04	3	2	6	Bajo	Aceptar	A.8.6
R-35	AD-05: Violacion de Ley 19.628 por fuga de datos personales	AD-05	2	4	8	Medio	Mitigar	A.5.34 (Privacidad y proteccion de PII), A.8.11 (Enmascaramiento de datos)

7. Plan de Tratamiento de Riesgos

7.1 Riesgos criticos y altos

R-06: Certificado emitido a identidad falsa (Riesgo: 15, Alto)

- **Tratamiento:** Mitigar
- **Controles:** A.5.17 (Verificacion de identidad), A.8.15 (Registro de eventos)
- **Acciones:**
 1. Implementar verificacion de identidad en dos etapas: documental (RUT/cedula) + biometrica (Smart-ID o presencial).
 2. Registrar cada verificacion en el log de auditoria con AuditAction correspondiente.
 3. Establecer proceso de revision cruzada: segundo oficial de RA verifica aleatoriamente el 10% de las aprobaciones.
 4. Integrar fuente de datos gubernamental (ClaveUnica o Registro Civil) para validacion de RUT.
- **Riesgo residual estimado:** 6 (Bajo)
- **Estado:** En implementacion (Smart-ID operativo, ClaveUnica pendiente)
- **Responsable:** Oficial de RA
- **Plazo:** 2027-Q1

7.2 Riesgos medios

R-02: Robo de clave privada CA intermedia (Riesgo: 10, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.24, A.8.2
- **Acciones:**
 1. Migrar almacenamiento de clave CA intermedia a HSM certificado FIPS 140-3 Nivel 2+.
 2. Implementar control de acceso dual para operaciones de firma CA.
 3. Registrar cada uso de la clave CA en log de auditoria.
 4. Alertas automaticas ante uso de clave fuera de horario o volumen anormal.
- **Riesgo residual estimado:** 4 (Bajo)
- **Estado:** Pendiente (HSM en proceso de adquisicion)
- **Responsable:** Administrador PKI
- **Plazo:** 2027-Q1

R-03: Intrusion a nodos BFT (Riesgo: 12, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.20, A.8.5
- **Acciones:**
 1. Restringir acceso SSH a IP whitelist con autenticacion por clave publica.
 2. Implementar deteccion de intrusos basada en anomalias en logs de acceso.
 3. Segmentar red: nodos BFT en red privada, solo API Gateway expuesto.
 4. Ejecutar escaneos de vulnerabilidad trimestrales.
- **Riesgo residual estimado:** 6 (Bajo)
- **Estado:** Parcial (TLS y ACL implementados, IDS pendiente)
- **Responsable:** Administrador Sistemas

- **Plazo:** 2027-Q1

R-04: DDoS contra API Gateway (Riesgo: 12, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.26
- **Acciones:**
 1. Configurar rate limiting por IP y por suscriptor (RATE_LIMIT_RPS/RPM/RPH).
 2. Habilitar proteccion DDoS a nivel de plataforma Fly.io.
 3. Implementar circuit breaker para endpoints de alta carga.
 4. Plan de escalamiento automatico ante picos de trafico.
- **Riesgo residual estimado:** 6 (Bajo)
- **Estado:** Parcial (rate limiting implementado, proteccion Fly.io activa)
- **Responsable:** Administrador Sistemas
- **Plazo:** 2027-Q1

R-05: Emision no autorizada por administrador (Riesgo: 10, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.5.3, A.8.15
- **Acciones:**
 1. Separar roles de administrador de sistema y operador PKI.
 2. Requerir aprobacion dual para emision de certificados (maker-checker).
 3. Alertas automaticas ante emision fuera de flujo RA autorizado.
 4. Revision trimestral de permisos y accesos.
- **Riesgo residual estimado:** 4 (Bajo)
- **Estado:** Parcial (ACL implementado, maker-checker pendiente)
- **Responsable:** Oficial de Seguridad
- **Plazo:** 2027-Q1

R-07: Falla de sincronizacion NTP en TSA (Riesgo: 12, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.17
- **Acciones:**
 1. Configurar multiples fuentes NTP independientes (minimo 3).
 2. NtpTimeSource::validate() verifica desviacion maxima de 1 segundo.
 3. Suspender emision de sellos de tiempo si la desviacion excede umbral.
 4. Alerta inmediata al Administrador de Sistemas ante falla NTP.
- **Riesgo residual estimado:** 4 (Bajo)
- **Estado:** Implementado (validacion NTP operativa)
- **Responsable:** Administrador Sistemas
- **Plazo:** Implementado

R-10: Harvest-now-decrypt-later sobre FES (Riesgo: 12, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.24
- **Acciones:**
 1. Ofrecer migracion voluntaria de suscriptores FES (Ed25519) a FEA (ML-DSA-65).

2. Para documentos de larga retencion, recomendar firma con FEA desde el inicio.
 3. Publicar guia de transicion para suscriptores.
 4. Monitorear avances en computacion cuantica y ajustar plazos de migracion.
 5. Mantener modo hibrido obligatorio (firma clasica + PQC) conforme a ANSSI Avis PQC (2024, seccion 2), combinando supuestos matematicos independientes (ECC + lattice).
 6. Selecccion de algoritmos alineada con BSI TR-02102-1 (2024): ML-DSA-65 “recommended”, Ed25519 “transitional”.
- **Riesgo residual estimado:** 6 (Bajo)
 - **Estado:** Parcial (ML-DSA-65 operativo, modo hibrido operativo, guia de migracion pendiente)
 - **Responsable:** Arquitecto Criptografico
 - **Plazo:** 2027-Q2

R-12: Fallo en transicion criptografica (Riesgo: 8, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.32, A.8.24
- **Acciones:**
 1. Mantener modo mixto: verify_signature() auto-detecta Ed25519 vs ML-DSA-65 por tamano.
 2. Pruebas de regresion: test suite Algorithm Death Day (22 tests, 7 fases).
 3. Rollback automatico si falla de verificacion > 0.1% en red mixta.
 4. Documentar procedimiento de rollback cripto en plan BCDR.
- **Riesgo residual estimado:** 4 (Bajo)
- **Estado:** Implementado (modo mixto y test suite operativos)
- **Responsable:** Arquitecto Criptografico
- **Plazo:** Implementado

R-13: Vulnerabilidad en implementacion ML-DSA-65 (Riesgo: 10, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.28, A.8.8
- **Acciones:**
 1. Utilizar implementacion de referencia NIST (PQClean) via pqcrypto-mldsa crate.
 2. Ejecutar KAT (Known Answer Tests) FIPS 204 en cada inicio del sistema.
 3. Monitorear avisos de seguridad de pqcrypto y NIST.
 4. Prohibir codigo unsafe en modulo de firma (enforced por crypto_boundary test).
 5. Preparar capacidad de migracion a SLH-DSA (FIPS 205) como algoritmo de respaldo.
- **Riesgo residual estimado:** 4 (Bajo)
- **Estado:** Implementado (KAT, crypto boundary enforced)
- **Responsable:** Arquitecto Criptografico
- **Plazo:** Continuo

R-14: Phishing contra operador PKI (Riesgo: 12, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.6.3, A.8.5

- **Acciones:**
 1. Capacitacion obligatoria en seguridad para todo el personal con acceso a sistemas (semestral).
 2. Implementar autenticacion multifactor (MFA) para todos los accesos administrativos.
 3. Simulacros de phishing trimestrales con reporte de resultados.
 4. Politica de reporte inmediato de correos sospechosos.
- **Riesgo residual estimado:** 6 (Bajo)
- **Estado:** Pendiente
- **Responsable:** Oficial de Seguridad
- **Plazo:** 2027-Q1

R-15: Compromiso de dependencia Rust (Riesgo: 8, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.25, A.5.21
- **Acciones:**
 1. Ejecutar cargo-audit en CI/CD ante cada cambio.
 2. Fijar versiones en Cargo.lock (sin rangos flotantes).
 3. Revisar manualmente actualizaciones de dependencias criticas (pqcrypto, ed25519-dalek, sha2).
 4. Limitar el numero de dependencias al minimo necesario.
- **Riesgo residual estimado:** 4 (Bajo)
- **Estado:** Implementado (cargo-audit en CI, versiones fijadas)
- **Responsable:** Lider Desarrollo
- **Plazo:** Continuo

R-17: Error de configuracion critica (Riesgo: 9, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.9
- **Acciones:**
 1. Documentar todas las variables de entorno criticas con valores por defecto seguros.
 2. Validacion de configuracion al inicio: RUST_BC_ENV=production requiere TLS_CERT_PATH/TLS_KEY_PATH.
 3. Alertas cuando ACL_MODE=permissive en produccion.
 4. Infrastructure-as-code para despliegues (scripts reproducibles).
- **Riesgo residual estimado:** 4 (Bajo)
- **Estado:** Parcial (validacion implementada, IaC pendiente)
- **Responsable:** Administrador Sistemas
- **Plazo:** 2027-Q1

R-18: Despliegue de codigo con errores (Riesgo: 9, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.25, A.8.31
- **Acciones:**
 1. Pipeline pre-push: cargo fmt --check, cargo clippy -- -D warnings, cargo test --lib.
 2. Separacion de ambientes: RUST_BC_ENV distingue produccion de desarrollo.

3. Despliegue canary: nuevo código en un nodo antes de propagación completa.
 4. Rollback automatizado ante falla de health check post-despliegue.
- **Riesgo residual estimado:** 4 (Bajo)
 - **Estado:** Implementado (pre-push hooks, separación de ambientes)
 - **Responsable:** Líder Desarrollo
 - **Plazo:** Implementado

R-20: Expiración de certificado TLS de nodo (Riesgo: 9, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.24
- **Acciones:**
 1. Monitorear fecha de expiración de todos los certificados TLS con alerta a 30 y 7 días.
 2. Automatizar renovación de certificados donde sea posible.
 3. Inventario centralizado de certificados con fechas de vencimiento.
- **Riesgo residual estimado:** 3 (Bajo)
- **Estado:** Pendiente
- **Responsable:** Administrador Sistemas
- **Plazo:** 2027-Q1

R-21: Terremoto en datacenter (Riesgo: 8, Medio)

- **Tratamiento:** Transferir
- **Controles:** A.5.29
- **Acciones:**
 1. Infraestructura en Fly.io con replicación en múltiples regiones.
 2. Seguro de continuidad operacional.
 3. Sitio secundario activable según plan BCDR (GOYA-BCDR-001).
 4. Ejercicio de DR anual.
- **Riesgo residual estimado:** 4 (Bajo)
- **Estado:** Parcial (Fly.io con replicación, DR plan documentado)
- **Responsable:** Operaciones
- **Plazo:** Continuo

R-25: Ataque Sybil a DPoS (Riesgo: 8, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.5, A.5.17
- **Acciones:**
 1. Requerir verificación de identidad RA para participar en delegación DPoS.
 2. Establecer stake mínimo para elegibilidad como delegado.
 3. Monitorear concentración de votos y patrones anómalos.
- **Riesgo residual estimado:** 4 (Bajo)
- **Estado:** Pendiente
- **Responsable:** Arquitecto de Sistema
- **Plazo:** 2027-Q2

R-26: Exfiltración de datos por personal (Riesgo: 8, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.5.10, A.6.2

- **Acciones:**
 1. Clausulas de confidencialidad en contratos de empleo.
 2. Control de acceso basado en roles (RBAC) con minimo privilegio.
 3. Monitoreo de acceso a datos sensibles con alertas ante volumen inusual.
 4. Procedimiento de revocacion de acceso inmediato al cese.
- **Riesgo residual estimado:** 4 (Bajo)
- **Estado:** Pendiente
- **Responsable:** Oficial de Seguridad
- **Plazo:** 2027-Q1

R-28: Error en verificacion de identidad RA (Riesgo: 12, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.5.17, A.8.15
- **Acciones:**
 1. Procedimiento RA documentado con checklist de verificacion.
 2. Capacitacion obligatoria para oficiales de RA.
 3. Auditoria mensual de verificaciones aprobadas (muestra aleatoria 5%).
 4. Doble verificacion para certificados FEA de alto valor.
- **Riesgo residual estimado:** 6 (Bajo)
- **Estado:** Parcial (procedimiento documentado, auditoria pendiente)
- **Responsable:** Oficial de RA
- **Plazo:** 2027-Q1

R-30: Agotamiento de almacenamiento en nodo (Riesgo: 9, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.6
- **Acciones:**
 1. Monitoreo de uso de disco con alerta al 80% de capacidad.
 2. Procedimiento de compactacion de RocksDB programado.
 3. Plan de escalamiento de almacenamiento documentado.
- **Riesgo residual estimado:** 3 (Bajo)
- **Estado:** Parcial (monitoreo basico implementado)
- **Responsable:** Administrador Sistemas
- **Plazo:** 2027-Q1

R-32: Bug en logica de consenso o firma (Riesgo: 10, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.8.28, A.8.25, A.8.29
- **Acciones:**
 1. Suite de pruebas BFT E2E (bft_e2e) y test de frontera criptografica (crypto_boundary).
 2. Pruebas de regresion automatizadas en cada cambio (cargo test –lib).
 3. Revision de codigo obligatoria para cambios en modulos consensus/ y signature/.
 4. Fuzzing periodico de funciones de firma y verificacion.
- **Riesgo residual estimado:** 4 (Bajo)
- **Estado:** Implementado (tests E2E y boundary enforced)
- **Responsable:** Lider Desarrollo
- **Plazo:** Continuo

R-35: Violacion de Ley 19.628 por fuga de datos personales (Riesgo: 8, Medio)

- **Tratamiento:** Mitigar
- **Controles:** A.5.34, A.8.11
- **Acciones:**
 1. Minimizar datos personales almacenados (solo los requeridos por DS 181).
 2. Cifrado de datos personales en reposo.
 3. Politica de retencion con eliminacion segura al vencer periodo legal.
 4. Registro de acceso a datos personales (log de auditoria).
 5. Procedimiento de respuesta a solicitudes de acceso y eliminacion (ARCO).
- **Riesgo residual estimado:** 4 (Bajo)
- **Estado:** Pendiente
- **Responsable:** Oficial de Seguridad
- **Plazo:** 2027-Q1

7.3 Riesgos bajos aceptados

Los siguientes riesgos se aceptan con monitoreo. Ver seccion 8 para justificacion formal.

ID	Riesgo	Nivel	Justificacion de aceptacion
R-01	5	Bajo	Clave raiz offline en fragmentos M-of-N, ceremoniade claves, sin conectividad de red
R-08	5	Bajo	Consenso BFT tolera hasta f nodos bizantinos en $3f+1$; validado con test suite
R-11	5	Bajo	ML-DSA-65 ya implementado; Ed25519 se usa solo para FES de bajo riesgo
R-24	6	Bajo	Verificacion de firma en cada mensaje gossip; nodos no autenticados son rechazados
R-27	5	Bajo	Separacion de funciones, auditoria completa, proceso de contratacion con verificacion
R-29	4	Bajo	mTLS obligatorio en P2P, verificacion de firma en protocolo gossip
R-31	6	Bajo	Infraestructura cloud con UPS del proveedor; riesgo transferido a Fly.io
R-33	4	Bajo	Infraestructura cloud; riesgo transferido a proveedor datacenter
R-34	6	Bajo	Rate limiting y capacidad actual suficiente; monitoreo de metricas activo

8. Declaracion de Aceptacion de Riesgos Residuales

La Gerencia General de Goya Ledger SpA declara haber revisado la evaluacion de riesgos contenida en este documento y acepta formalmente los riesgos residuales detallados a continuacion, considerando que los controles implementados y planificados reducen el riesgo a niveles aceptables para la operacion del PSC.

Riesgos residuales aceptados

ID	Descripcion del riesgo residual	Nivel residual	Justificacion
R-01	Riesgo residual de compromiso de clave raiz CA	2 (Bajo)	La clave raiz se almacena offline en fragmentos M-of-N distribuidos en custodios independientes. El acceso requiere reunion fisica de multiples custodios bajo ceremonia auditada. La probabilidad residual se considera aceptable.
R-08	Riesgo residual de manipulacion de consenso BFT	2 (Bajo)	El protocolo HotStuff tolera hasta f nodos bizantinos en configuracion $3f+1$. La manipulacion requiere comprometer simultaneamente mas de un tercio de los nodos validadores, lo cual se considera inviable dado el control de identidad sobre los nodos.
R-11	Riesgo residual de ruptura cuantica de Ed25519	3 (Bajo)	ML-DSA-65 esta operativo como alternativa. Ed25519 se usa exclusivamente para FES (firma simple), cuyos documentos tienen menor requerimiento de permanencia. La migracion esta disponible y es voluntaria para suscriptores.
R-24		2 (Bajo)	

ID	Descripcion del riesgo residual	Nivel residual	Justificacion
	Riesgo residual de envenenamiento gossip		Cada mensaje gossip se verifica criptograficamente. Mensajes con firma invalida se descartan sin procesar. No se propagan datos no verificados.
R-27	Riesgo residual de sabotaje interno	3 (Bajo)	Controles de segregacion de funciones, auditoria completa de acciones privilegiadas, y proceso de contratacion con verificacion de antecedentes mitigan este riesgo a nivel aceptable.
R-29	Riesgo residual de MITM en red P2P	2 (Bajo)	mTLS obligatorio con certificados mutuos y verificacion de firma en protocolo gossip eliminan vectores de ataque MITM practicos.
R-34	Riesgo residual de degradacion de rendimiento	3 (Bajo)	La capacidad actual excede la demanda proyectada. Rate limiting protege contra sobrecarga. Monitoreo continuo permite detectar tendencias antes de impacto operacional.

Firma de aceptacion:

Gerente General, Goya Ledger SpA Fecha: _____

9. Comunicacion de Riesgos

9.1 Partes interesadas

Parte interesada	Informacion que recibe	Frecuencia	Canal
Directorio / Gerencia General	Resumen ejecutivo de riesgos criticos y altos, estado de tratamiento	Trimestral	Informe escrito + presentacion
Entidad Acreditadora (Subsecretaria de Economia)	Documento PS01 completo, actualizaciones ante cambios materiales	Anual o ante cambios	Correo a oficinadepartesgd@economia.cl
Oficial de Seguridad	Registro de riesgos completo, metricas de KPI	Mensual	Dashboard interno
Equipo de operaciones	Riesgos operacionales relevantes, procedimientos de mitigacion	Mensual	Reunion de equipo
Suscriptores de certificados	Incidentes que afecten la validez de sus certificados	Ante incidentes P1/P2	Correo + portal web
Auditor externo independiente	Acceso completo al proceso de gestion de riesgos	Anual (auditoria)	Reunion presencial + documentacion
Proveedores criticos (Fly.io)	Requisitos de seguridad y disponibilidad	Ante cambios contractuales	Correo + SLA

9.2 Informes periodicos

Informe	Contenido	Destinatario	Frecuencia
Dashboard de riesgos	Estado de cada riesgo, avance de tratamiento, KPIs	Oficial de Seguridad	Continuo
	Riesgos nuevos, cambios de nivel,	Gerencia General	Trimestral

Informe	Contenido	Destinatario	Frecuencia
Informe trimestral de riesgos	tratamientos completados		
Informe anual de revision	Evaluacion completa, efectividad de controles, recomendaciones	Directorio + Entidad Acreditadora	Anual
Alerta de riesgo emergente	Nuevo riesgo critico o alto identificado fuera de ciclo	Gerencia General	Inmediato

10. Monitoreo y Revision

10.1 Revision periodica

Actividad	Frecuencia	Responsable
Revision completa del registro de riesgos	Anual (minimo)	Oficial de Seguridad + Auditor externo
Revision de efectividad de controles	Semestral	Oficial de Seguridad
Actualizacion de catalogo de amenazas	Semestral	Arquitecto de Sistema
Revision de vulnerabilidades tecnicas	Trimestral	Lider Desarrollo
Escaneo de vulnerabilidades en infraestructura	Trimestral	Administrador Sistemas
Verificacion de cumplimiento de plazos de tratamiento	Mensual	Oficial de Seguridad

10.2 Revisiones por evento (triggers)

Se inicia una revision extraordinaria del registro de riesgos ante cualquiera de los siguientes eventos:

1. **Incidente de seguridad** clasificado P1 o P2 segun GOYA-IRP-001.
2. **Cambio significativo en la infraestructura:** migracion de proveedor cloud, cambio de region, adiccion de nuevos servicios.
3. **Cambio en el entorno regulatorio:** modificacion de la Ley 19.799, nuevo decreto, cambio en guia EA-103.

4. **Nueva amenaza identificada:** publicacion de CVE critico en dependencia, avance material en computacion cuantica, nuevo vector de ataque a PKI.
5. **Cambio organizacional:** incorporacion o salida de personal clave, cambio de estructura.
6. **Resultado de auditoria externa** que identifique brechas no cubiertas.
7. **Cambio criptografico:** nueva version de FIPS 204, depreciacion de algoritmo, actualizacion de pqcrypto crate.
8. **Expansion de servicios:** nuevos tipos de certificados, nuevas jurisdicciones, nuevo servicio de confianza.

10.3 KPIs de gestion de riesgos

KPI	Objetivo	Medicion
Porcentaje de riesgos altos/criticos con tratamiento activo	100%	Mensual
Tiempo promedio de implementacion de tratamiento (riesgos altos)	< 90 dias	Trimestral
Porcentaje de tratamientos completados dentro de plazo	> 85%	Trimestral
Numero de riesgos nuevos identificados por revision	Registro	Cada revision
Porcentaje de reduccion de riesgo residual anual	> 10%	Anual
Incidentes causados por riesgos no identificados	0	Anual
Cobertura del catalogo de amenazas vs benchmarks NIST	> 90%	Anual

10.4 Proceso de actualizacion

1. El Oficial de Seguridad recopila insumos (incidentes, cambios, nuevas amenazas).
2. Se actualiza el catalogo de amenazas y la evaluacion de vulnerabilidades.

3. Se recalculan probabilidad e impacto de riesgos existentes.
4. Se agregan riesgos nuevos al registro.
5. Se revisan y ajustan planes de tratamiento.
6. Se actualiza la declaracion de aceptacion de riesgos residuales.
7. Se aprueba la version actualizada por Gerencia General.
8. Se comunica a las partes interesadas segun la tabla de comunicacion (seccion 9.1).

11. Requisito de Auditoria Externa Independiente

11.1 Requisito normativo

La Guia de Acreditacion EA-103 v2.1 establece que el proceso de gestion de riesgos debe ser “realizado o auditado por un ente externo independiente y calificado.” Goya Ledger opta por la modalidad de auditoria del proceso por un ente externo, manteniendo la ejecucion interna del proceso.

11.2 Perfil del auditor externo

Requisito	Detalle
Independencia	Sin relacion comercial, financiera o personal con Goya Ledger SpA
Calificacion	Certificacion ISO 27001 Lead Auditor o CISA, con experiencia en PKI/TSP
Experiencia	Minimo 3 anos en auditoria de seguridad de la informacion en el sector financiero o de servicios de confianza
Alcance	Revision completa del proceso PS01: metodologia, registro de riesgos, tratamientos, aceptacion, monitoreo

11.3 Plan de auditoria

Actividad	Plazo	Estado
Seleccion y contratacion de auditor externo	2027-Q1	Pendiente
Primera auditoria completa del proceso PS01	2027-Q2	Pendiente
Remediacion de hallazgos de auditoria	2027-Q3	Pendiente
Presentacion de informe de auditoria a Entidad Acreditadora	2027-Q3	Pendiente
		Planificado

Actividad	Plazo	Estado
Auditorias de seguimiento anuales	Anual a partir de 2028	

11.4 Entregables de la auditoria

1. Informe de auditoria firmado por el auditor con opinion sobre la adecuacion del proceso.
2. Lista de hallazgos clasificados por severidad.
3. Recomendaciones de mejora.
4. Declaracion de independencia del auditor.
5. Carta de representacion de la gerencia.

12. Referencias

Referencia	Descripcion
GOYA-IRP-001	Plan de Respuesta a Incidentes
GOYA-BCDR-001	Plan de Continuidad de Negocio y Recuperacion ante Desastres
GOYA-PHYS-001	Requisitos de Seguridad Fisica
ISO/IEC 27001:2022	Sistemas de gestion de seguridad de la informacion
ISO/IEC 27002:2022	Controles de seguridad de la informacion
ISO/IEC 27005:2022	Gestion de riesgos de seguridad de la informacion
NIST SP 800-30 Rev.1	Guia para la evaluacion de riesgos
NIST FIPS 204	ML-DSA (Module-Lattice-Based Digital Signature Standard)
Ley 19.799	Documentos electronicos, firma electronica y servicios de certificacion
DS 181/2002	Reglamento de la Ley 19.799
Decreto 24/2019	Norma tecnica para firma electronica avanzada
Ley 19.628	Proteccion de la vida privada
Ley 21.459	Delitos informaticos
EA-103 v2.1	Guia de acreditacion de PSC
ETSI TS 102 042	Requisitos de politica para CA
ETSI EN 319 401	Requisitos generales para prestadores de servicios de confianza
BSI TR-02102-1 (2024)	Kryptographische Verfahren: Empfehlungen und Schlüssellängen (recomendaciones de algoritmos criptograficos)
ANSSI Avis PQC (2024)	

Referencia	Descripcion
	Avis relatif a la migration vers la cryptographie post-quantique (modo hibrido obligatorio)